

Scenario 3 – Account Recovery & Profile Management Flow

Owner: Ananth Chowdary Ramineni
Reviewer: BTH Master's Thesis
Contributors:
Date Generated: Fri Aug 21 2026

Executive Summary

High level system description

Web-based account recovery and profile management system allowing registered users to request password resets, validate reset tokens, update passwords, retrieve and modify profile information through backend services using secure token validation and persistent user storage.

Summary

Total Threats	46
Total Mitigated	0
Total Open	46
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	46

Account Recovery & Profile Management Flow

Registered User (Browser) (Actor)

Description: Registered user interacting with the account recovery and profile management system through a web browser.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	No Suggestions available		TBD	Open		No suggestions available for this context. Add one manually please	

Web Frontend Interface (Process)

Description: Receives password reset requests, accepts reset tokens and new passwords, forwards profile requests, and communicates with backend services.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
5	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
6	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
7	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
8	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

Account Management Service (Process)

Description: Coordinates password reset operations, validates reset tokens, verifies user accounts, updates passwords, and communicates with backend services.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
28	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
29	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
30	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation

Number	Title	Type	Severity	Status	Score	Description	Mitigations
31	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
32	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

User Profile API Handler (Process)

Description: Retrieves and updates user profile information after successful authentication and authorization.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
22	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
23	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
24	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
25	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

Backend User Database (Store)

Description: Stores user credentials, password reset tokens, account records, and profile information.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
14	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
15	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action
16	Credential cracking	Information disclosure	TBD	Open		See OWASP Automated Threat #7: Brute force, dictionary and guessing attacks used against authentication processes of the application to identify valid account credentials	Defences include restriction of excessive authentication attempts, control of interaction frequency and enforcement of a single unique action
17	Account creation	Elevation of privilege	TBD	Open		See OWASP Automated Threat #19: Bulk account creation, and sometimes profile population, by using the application’s account signup processes	Defences include control of interaction frequency, enforcement of a single unique a action and enforcement of behavioral workflow

Number	Title	Type	Severity	Status	Score	Description	Mitigations
18	Account aggregation	Spoofing	TBD	Open		See OWASP Automated Threat #20: Compilation of credentials and information from multiple application accounts into another system	Defences include control of interaction frequency and prevention of abuse of functionality
19	Vulnerable encryption algorithms	Information disclosure	TBD	Open		Out of date encryption algorithms are vulnerable and have known vulnerabilities	Use up to date cryptography for all signatures and encryption

Reset Request (Data Flow)

Description: Registered user submits a password reset request through the web interface.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
3	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Forwarded Request (Data Flow)

Description: Web frontend forwards the password reset request to the backend account management service.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
26	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Profile API Request (Data Flow)

Description: Account management service exchanges profile-related API requests and responses with the user profile API handler.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
38	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Token Generation Request (Data Flow)

Description: Account management service requests generation or validation of password reset tokens.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
33	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Password Reset Token Delivery (Data Flow)

Description: Generated password reset token is delivered securely to the registered user.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
40	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Password Reset Token and New Password (Data Flow)

Description: User submits the received reset token together with the new password.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
10	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Forwarded Token and Password (Data Flow)

Description: Frontend forwards the token and new password for verification.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
27	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Password Update (Data Flow)

Description: Validated password reset request updates the stored password.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
39	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Authenticated Profile API Request (Data Flow)

Description: Authenticated user requests profile retrieval or modification.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
12	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Profile Query or Update (Data Flow)

Description: Backend accesses stored profile information after validating the authenticated session.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Account-Related Question (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Sanitized Prompt and Approved Context (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Processed AI Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

AI Support Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Account-related request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Account-related request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Prompt + Approved Context (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Generated Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Password Reset Token Module (Process)

Description: Generates password reset tokens, validates submitted reset tokens, and coordinates password recovery operations.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
34	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
35	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
36	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
37	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

EE2 External LLM Provider (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

P4 AI Account Support Assistant (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
41	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
42	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
43	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

P5 LLM Integration Service (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
44	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
45	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
46	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock